

SIMATS ENGINEERING

ASSESSMENT TOOL 3

Name	SHIAK REEHAN
Register Number	192565071
Date	
Time	1hr

COURSE NAME: Cybersecurity Incident Handling And Response
COURSE CODE: CSA60

COURSE OUTCOME COVERED

CO5: *Implement database operations using query processing, optimization, and transaction management to ensure consistency and reliability. (BL3, BL4)*

Activity Tool : Mock Interview (Low)
Assessment Tool Weightage: 10%

Code of Conduct:

I _____shaikreehan.192565071_____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Shaik Reehan

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
SIEM Data Analysis and Metric Selection	25%	Thoroughly analyzes relevant SIEM and incident data and selects appropriate metrics such as MTTD, MTTR, alert volume, false-positive rate, SLA compliance, and incident recurrence.	Analyzes relevant SIEM data and selects most appropriate metrics with minor omissions.	Performs basic analysis and selects limited metrics with insufficient justification.	Unable to analyze SIEM data or identify appropriate metrics.
Dashboard Design and Visualization	25%	Develops a clear, professional, and interactive dashboard that effectively presents security metrics, incident trends, severity levels, response performance, and key security indicators.	Develops a well-organized dashboard with most relevant metrics and visualizations with minor issues.	Creates a basic dashboard but lacks important metrics, visualizations, or organization.	Unable to develop a meaningful dashboard or present metrics effectively.
KPI Analysis and Incident Response Performance	20%	Accurately analyzes KPIs such as MTTD, MTTR, incident resolution time, false-positive rate, escalation rate, and SLA.	Correctly analyzes most KPIs and identifies major performance trends with minor gaps.	Provides basic KPI analysis but misses important trends or relationships.	Unable to correctly analyze KPIs or evaluate incident response performance.
Continuous Improvement and Recommendations	20%	Identifies security weaknesses and recurring issues and provides specific, prioritized, and actionable recommendations to improve detection, response, SOC processes, and security controls.	Identifies major improvement areas and provides relevant recommendations with minor gaps.	Provides general recommendations with limited connection to the analyzed metrics.	Unable to identify meaningful improvement areas or provide appropriate recommendations.
Documentation, Reporting, and Presentation	10%	Provides clear, professional documentation explaining the dashboard, metrics, findings, trends, recommendations, and continuous improvement actions.	Documentation is well organized and clearly explains most dashboard findings with minor omissions.	Documentation is partially organized with limited analysis or supporting evidence.	Documentation is incomplete, poorly organized, and lacks clear findings or conclusions.

1. SIEM Alert Analysis and False-Positive Reduction

Introduction

A Security Information and Event Management (SIEM) system collects and correlates security events from sources such as firewalls, servers, endpoints, applications, identity systems, and network devices. A SOC may receive thousands of alerts, but not every alert represents a genuine security incident.

A high number of false positives can cause **alert fatigue**, waste analyst time, delay the investigation of genuine threats, and reduce SOC effectiveness. Therefore, the SOC should systematically analyze alert data, identify the causes of false positives, tune detection rules, and continuously measure the results.

A. SIEM Alert Analysis

The first step is to collect historical SIEM alert data and analyze it by:

- Alert type
- Detection rule
- Severity
- Source system
- Affected asset
- Frequency
- Time of occurrence
- Analyst disposition
- True positive/false positive classification
- Investigation time
- Escalation status
- Final incident outcome

The analyst should determine which rules generate the highest number of alerts and which rules have the highest false-positive rates.

Example Alert Analysis

Detection Rule	Total Alerts	True Positives	False Positives	False-Positive Rate
Multiple Failed Logins	1,000	100	900	90%
Suspicious PowerShell	500	150	350	70%
Malware Detection	200	160	40	20%
Impossible Travel	800	80	720	90%
Privilege Escalation	100	70	30	30%

This analysis shows that **Multiple Failed Logins** and **Impossible Travel** require immediate tuning because they generate large numbers of false positives.

B. Key Causes of False Positives

False positives can occur for several reasons.

1. Poorly Configured Detection Thresholds

A rule may trigger an alert whenever five failed logins occur.

However, legitimate users may occasionally enter incorrect passwords multiple times.

Instead of:

5 failed logins → Alert

the organization could use contextual conditions such as:

10 failed logins + unusual IP + unusual location + privileged account → High-risk alert

2. Legitimate Administrative Activity

Security tools may detect normal activities performed by:

- System administrators
- IT support teams
- Security analysts
- Automated management systems
- Backup systems

These activities may appear suspicious even though they are authorized.

3. Normal Business Behavior

Examples include:

- Employees travelling between locations
- Remote workers using VPNs
- Large legitimate file transfers
- Scheduled vulnerability scans

- Automated scripts
- Software deployment activities

If the SIEM does not understand this context, it may generate unnecessary alerts.

4. Outdated Threat Rules

Detection rules may remain unchanged even though the organization's environment has changed.

For example, a company may introduce a new cloud service or VPN system that changes normal authentication patterns. Existing rules may then generate excessive alerts.

5. Duplicate Alerts

Multiple security tools may detect the same event.

For example:

Firewall Alert + EDR Alert + IDS Alert + SIEM Correlation Alert

may all represent one underlying incident.

Alert correlation should combine related events into a single investigation where appropriate.

C. Detection Rule Tuning

After identifying false-positive causes, the SOC should tune detection rules.

Rule-Tuning Techniques

1. Adjust thresholds.
2. Add contextual conditions.
3. Create allowlists for verified legitimate activities.
4. Exclude known trusted systems where appropriate.
5. Add user and asset risk information.
6. Correlate multiple events before generating high-severity alerts.
7. Remove duplicate alerts.
8. Update outdated detection logic.
9. Use threat intelligence.
10. Continuously review rule performance.

Example

Original rule:

5 failed logins → Alert

Improved rule:

10+ failed logins + new source IP + unusual location + privileged account → High-priority alert

This reduces unnecessary alerts while maintaining detection capability.

D. Alert Correlation

Instead of treating every event independently, the SIEM should correlate related events.

For example:

Failed login

↓

Successful login from unusual location

↓

Privilege escalation

↓

Suspicious PowerShell execution

↓

Outbound connection to malicious IP

These events together provide stronger evidence of compromise than any individual event.

Therefore, correlation can reduce false positives and improve detection accuracy.

E. Measuring Improvement

After tuning detection rules, the SOC should compare performance before and after tuning.

Before Tuning

- 10,000 alerts/month
- 7,000 false positives
- False-positive rate = 70%
- Average investigation time = 15 minutes

After Tuning

- 6,000 alerts/month
- 2,400 false positives
- False-positive rate = 40%
- Average investigation time = 8 minutes

The improvement can be measured using:

$$\text{False-Positive Rate} = (\text{False Positives} \div \text{Total Alerts}) \times 100$$

Before:

$$(7,000 / 10,000) \times 100 = 70\%$$

After:

$$(2,400 / 6,000) \times 100 = 40\%$$

Therefore, the false-positive rate decreased by **30 percentage points**.

However, the SOC should not optimize only for fewer alerts. A rule that produces very few alerts but misses real attacks is also ineffective. **False negatives and detection coverage must therefore be monitored alongside false positives.**

F. KPIs for SIEM Alert Quality

The following KPIs should be monitored.

1. Alert Volume

Measures the total number of alerts generated.

$$\text{Alert Volume} = \text{Total alerts during a specific period}$$

A sudden increase may indicate:

- New attack activity
- Misconfigured rules

- System changes
 - Duplicate alerts
-

2. False-Positive Rate

$$\text{False-Positive Rate} = \text{False Positives} \div \text{Total Alerts} \times 100$$

A decreasing rate generally indicates improved alert quality.

3. True-Positive Rate

Measures the percentage of alerts that represent genuine security threats.

$$\text{True-Positive Rate} = \text{True Positives} \div \text{Total Alerts} \times 100$$

4. Mean Time to Triage

Measures the average time analysts require to determine whether an alert is legitimate or benign.

A lower value indicates improved analyst efficiency.

5. Mean Time to Detect (MTTD)

Measures the average time required to detect an actual security incident.

$$\text{MTTD} = \text{Total Detection Time} \div \text{Number of Incidents}$$

6. Mean Time to Respond (MTTR)

Measures how quickly analysts begin responding after an incident is detected.

$$\text{MTTR} = \text{Total Response Time} \div \text{Number of Incidents}$$

7. Alert-to-Incident Conversion Rate

Measures how many SIEM alerts become confirmed incidents.

$$\text{Conversion Rate} = \text{Confirmed Incidents} \div \text{Total Alerts} \times 100$$

A very low rate may indicate excessive alert noise.

8. Analyst Workload

Track:

- Alerts handled per analyst
- Average investigation time
- Number of unresolved alerts
- Alert backlog
- After-hours workload

This helps management determine whether staffing levels are appropriate.

2. Incident Response Continuous Improvement Dashboard

Introduction

A continuous improvement dashboard provides management and SOC teams with a centralized view of security detection and incident-response performance.

The dashboard should combine **SIEM data, incident tickets, endpoint data, network alerts, SLA information, and historical incident records.**

The dashboard should support both:

- **Operational monitoring** for SOC analysts
 - **Management and governance reporting** for security leadership
-

A. Dashboard Objectives

The dashboard should answer the following questions:

1. How many security alerts are being generated?
 2. How many are genuine incidents?
 3. What types of incidents are increasing?
 4. How quickly are threats detected?
 5. How quickly are incidents resolved?
 6. Are SLA requirements being met?
 7. How frequently are incidents recurring?
 8. Which detection rules generate excessive false positives?
 9. Where are response bottlenecks occurring?
 10. What security improvements should be prioritized?
-

B. Dashboard Structure

A professional dashboard can contain the following sections:

Section 1 – Executive Security Summary

Display:

- Total alerts
- Confirmed incidents
- Critical incidents

- Open incidents
- SLA compliance
- MTTD
- MTTR
- Recurring incident rate

Section 2 – SIEM Alert Quality

Display:

- Alert volume
- True positives
- False positives
- False-positive rate
- Alert-to-incident conversion rate
- Top noisy detection rules
- Analyst triage time

Section 3 – Incident Trends

Display:

- Incidents by month
- Incidents by severity
- Incidents by category
- Incidents by affected system
- Recurring incidents

Section 4 – Response Performance

Display:

- MTTD
- MTTR
- Mean Time to Contain
- Mean Time to Resolve
- Escalation rate
- SLA compliance

Section 5 – Continuous Improvement

Display:

- Open corrective actions
- Overdue corrective actions
- Recurring root causes
- Detection rules requiring tuning
- Security controls requiring improvement

C. Suitable Dashboard Visualizations

Metric	Recommended Visualization
Alert volume over time	Line chart
Incidents by severity	Bar chart
Incident categories	Bar/pie chart
False-positive rate	KPI card + trend line
MTTD	KPI card + line chart
MTTR	KPI card + line chart
SLA compliance	Gauge/KPI card
Recurring incidents	Trend chart
Top detection rules	Horizontal bar chart
Incident status	Stacked bar chart
Escalation rate	KPI card
Analyst workload	Bar chart
Corrective actions	Progress chart

The dashboard should use filters such as:

- Date range
- Severity
- Incident type
- Department
- Asset
- Detection rule
- Analyst/team
- SLA status

This allows users to investigate specific areas rather than viewing only aggregate data.

D. KPI Analysis

1. Mean Time to Detect

A high MTTD indicates that threats are remaining undetected for too long.

Improvement actions

- Improve SIEM correlation.
- Add better endpoint monitoring.

- Improve threat intelligence.
 - Create additional detection rules.
 - Reduce detection gaps.
-

2. Mean Time to Respond

A high MTTR indicates that the SOC is taking too long to begin effective response.

Improvement actions

- Create response playbooks.
 - Improve alert prioritization.
 - Automate routine actions.
 - Improve analyst training.
 - Strengthen escalation procedures.
-

3. Incident Resolution Time

Measures how long incidents take to completely resolve.

A rising resolution time may indicate:

- Lack of technical resources
 - Complex incidents
 - Poor coordination
 - Delayed escalation
 - Incomplete playbooks
-

4. SLA Compliance

SLA Compliance = Incidents Resolved Within SLA ÷ Total Incidents × 100

For example:

If 95 out of 100 incidents are resolved within their SLA:

SLA Compliance = 95%

A declining SLA compliance rate should trigger management investigation.

5. Escalation Rate

$$\text{Escalation Rate} = \text{Escalated Incidents} \div \text{Total Incidents} \times 100$$

This can identify whether frontline analysts are appropriately escalating serious incidents.

6. Recurring Incident Rate

$$\text{Recurring Incident Rate} = \text{Recurring Incidents} \div \text{Total Incidents} \times 100$$

A high recurring rate indicates that the organization is treating symptoms instead of fixing root causes.

E. Incident Trend Analysis

Historical trends should be displayed to identify changes over time.

For example:

Month	Alerts	Confirmed Incidents	False-Positive Rate	MTTD	MTTR
January	8,000	320	68%	45 min	90 min
February	8,500	300	62%	40 min	80 min
March	7,500	280	55%	32 min	65 min
April	6,800	260	45%	25 min	50 min

This trend suggests that alert tuning and process improvements are reducing false positives and improving response performance.

F. Recurring Incident Analysis

Recurring incidents should be grouped according to root cause.

For example:

Recurring Problem	Frequency	Risk	Recommended Action
Phishing	40	Medium	Improve email filtering and awareness
Credential compromise	25	High	Enforce MFA
Unpatched systems	20	High	Improve patch management

Recurring Problem	Frequency	Risk	Recommended Action
Malware	15	High	Strengthen endpoint protection
Unauthorized access	10	Critical	Improve IAM and monitoring

The organization should prioritize recurring problems according to **risk and business impact**, not simply frequency.

G. Continuous Improvement Recommendations

Priority 1 – Reduce False Positives

- Tune high-volume detection rules.
- Add contextual information.
- Correlate related events.
- Remove duplicate alerts.
- Review detection rules regularly.

Expected result: Lower alert fatigue and improved analyst productivity.

Priority 2 – Improve Detection

- Improve SIEM correlation.
- Integrate EDR, firewall, IAM, and threat-intelligence data.
- Develop detections for important attack techniques.
- Monitor detection coverage.

Expected result: Lower MTTD and better threat visibility.

Priority 3 – Improve Response

- Develop standardized incident-response playbooks.
- Automate repetitive tasks.
- Improve analyst training.
- Establish clear incident ownership.

Expected result: Lower MTTR and resolution time.

Priority 4 – Improve Escalation

Create a clear escalation matrix based on:

- Severity
- Business impact
- Data sensitivity
- Affected assets
- Regulatory requirements

Expected result: Faster escalation of critical incidents.

Priority 5 – Improve Recovery

- Test backup and recovery procedures.
- Establish recovery playbooks.
- Verify system integrity before returning systems to production.
- Monitor restored systems for recurring compromise.

Expected result: Reduced downtime and faster recovery.

H. Continuous Improvement Cycle

The dashboard should support a repeating improvement cycle:

Collect SIEM + Incident Data



Measure KPIs



Identify Trends and Weaknesses



Perform Root Cause Analysis



Implement Corrective Actions



Tune Detection and Response Processes



Measure Results



Repeat

This ensures that dashboard information leads to actual security improvements rather than becoming a passive reporting tool.

I. Example Management Dashboard Summary

KPI	Current	Target	Status	Recommended Action
Alert Volume	10,000/month	<8,000	Needs Review	Tune noisy rules
False-Positive Rate	65%	<40%	Poor	Rule optimization
MTTD	40 min	<20 min	Needs Improvement	Improve detection
MTTR	75 min	<30 min	Poor	Playbooks + automation
SLA Compliance	85%	>95%	Needs Improvement	SLA monitoring
Escalation Rate	18%	Risk-based	Review	Improve escalation rules

KPI	Current	Target	Status	Recommended Action
Recurring Incidents	12%	<5%	Poor	Root-cause remediation
Critical Incident Resolution	6 hrs	<4 hrs	Needs Improvement	Improve coordination

Conclusion

An effective SIEM strategy should not focus only on generating more alerts. The goal is to produce **high-quality, actionable alerts that allow analysts to detect genuine threats quickly**. By analyzing alert volume, false-positive rates, true-positive rates, triage time, MTTD, MTTR, and alert-to-incident conversion rates, the SOC can identify noisy detection rules and improve alert quality.

A continuous improvement dashboard should combine **SIEM and incident-response data** to provide a complete view of security performance. It should display alert trends, incident severity, false positives, MTTD, MTTR, resolution time, SLA compliance, escalation rate, recurring incidents, analyst workload, and corrective actions.

The dashboard should then connect these measurements to specific improvements such as **SIEM rule tuning, alert correlation, automation, response playbooks, improved escalation, analyst training, and root-cause remediation**.